TP : IDS/IPS - SNORT

- Une machine virtuelle pfSense
- Une machine virtuelle Debian
- Une machine virtuelle Kali Linux

Dans une premier temps configurez une carte réseau en accès par pont (dhcp) et une en réseau interne (nommée « LAN ») sur le pfSense.
Configurez l'interface LAN avec l'adresse IP 172.16.255.254/16

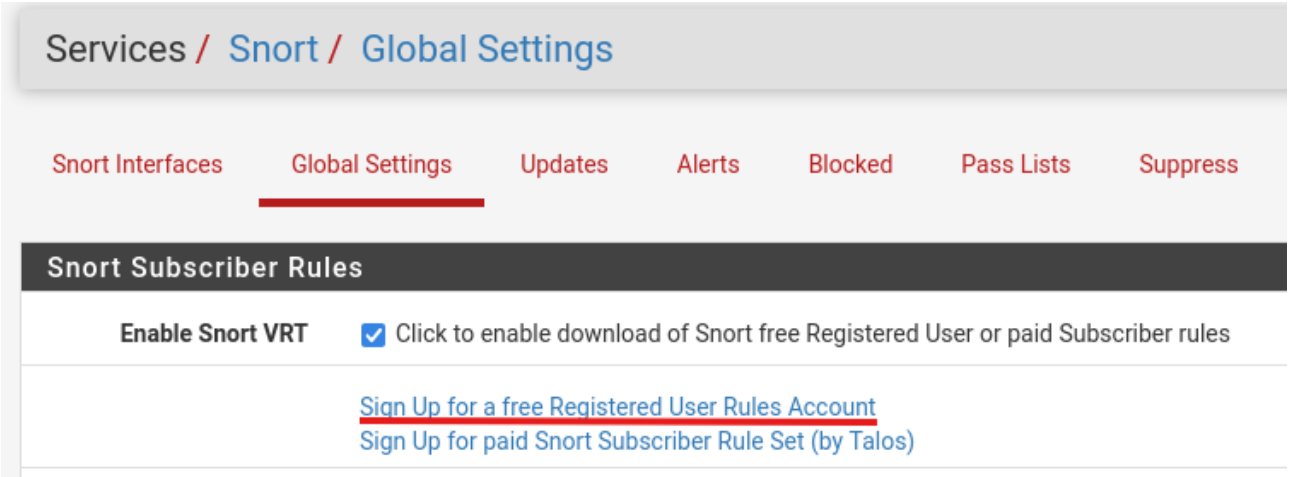
Sur la machine cliente, connectez une carte réseau en réseau interne (sur celui créé précédemment, nommé « LAN ») et fixez l'adresse IP 172.16.0.1/16.
Rendez-vous sur la page web de configuration du pfSense depuis la machine cliente.

Installation

- Rendez-vous dans la l'onglet System/Package Manager/Available Packages, et recherchez « Snort » dans la barre de recherche. Installez ce paquet, si cette installation se déroule correctement vous obtiendrez un message vous l'indiquant.

Configuration

- Dans la partie Services, rendez-vous dans la partie Snort.
- Dans l'onglet « Global Settings », créez-vous un compte **gratuit** Snort



- Suivez les étapes de création. Connectez-vous (vous devrez valider votre mail) puis rendez-vous dans la partie « Oinkcode ». Copiez-le, puis retournez sur la page de configuration du pfSense.
- Collez-le dans la partie « Snort Oinkmaster Code »

- Une fois cela fait, activez les options suivantes :
    - Snort VRT
    - Snort GLPv2
    - ET Open
    - OpenAppID
    - AppID Open Text Rules
    - FEODO Tracker Botnet C2 IP Rules

- Dans la partie « Update Interval », choisissez « 12 HOURS ».
- Sauvegardez vos modifications.

- Dans l'onglet « Updates », cliquez sur « Update Rules »

- Dans l'onglet « Snort Interfaces », cliquez sur « Add » puis complétez la section comme suivant :

Send Alerts to System Log	☐ Snort will send Alerts to the firewall's system log. Default is Not Checked.
Enable Packet Captures	☐ Checking this option will automatically capture packets that generate a Snort alert into a tcpdump compatible file
Enable Unified2 Logging	☐ Checking this option will cause Snort to simultaneously log alerts to a unified2 binary format log file in the logging subdirectory for this interface. Default is Not Checked. Log size and retention limits for the Unified2 log should be configured on the LOG MGMT tab when this option is enabled.

Block Settings

Block Offenders	☑ Checking this option will automatically block hosts that generate a Snort alert. Default is Not Checked.
IPS Mode	Legacy Mode Select blocking mode operation. Legacy Mode inspects copies of packets while Inline Mode inserts the Snort inspection engine into the network stack between the NIC and the OS. Default is Legacy Mode. Legacy Mode uses the PCAP engine to generate copies of packets for inspection as they traverse the interface. Some "leakage" of packets will occur before Snort can determine if the traffic matches a rule and should be blocked. Inline mode instead intercepts and inspects packets before they are handed off to the host network stack for further processing. Packets matching DROP rules are simply discarded (dropped) and not passed to the host network stack. No leakage of packets occurs with Inline Mode. WARNING: Inline Mode only works with NIC drivers which properly support Netmap! Supported drivers: bnxt, cc, cxgbe, cxl, em, em, ena, ice, igb, igc, ix, ixgbe, ixl, lem, re, vmx, vtnet. If problems are experienced with Inline Mode, switch to Legacy Mode instead.
Kill States	☑ Checking this option will kill firewall established states for the blocked IP. Default is checked.
Which IP to Block	BOTH Select which IP extracted from the packet you wish to block. Default is BOTH.

Detection Performance Settings

Search Method	AC-BNFA Choose a fast pattern matcher algorithm. Default is AC-BNFA.
Split ANY-ANY	☐ Enable splitting of ANY-ANY port group. Default is Not Checked.

- Sauvegardez vos modifications.
- Activez l'interface nouvellement créée.

- Toujours dans l'onglet « Snort Interfaces », cliquez sur « Wan Categories » puis remplissez les sections comme indiqué dans les captures d'écran suivantes :

pfsense COMMUNITY EDITION — System — Interfaces — Firewall — Services — VPN — Status — Diagnostics — Help

1

Services / Snort / Interface Settings / WAN - Categories

Snort Interfaces | Global Settings | Updates | Alerts | Blocked | Pass Lists | Suppress | IP Lists | SID Mgmt | Log Mgmt | Sync

WAN Settings | WAN Categories | WAN Rules | WAN Variables | WAN Preprocs | WAN IP Rep | WAN Logs

Automatic Flowbit Resolution

Resolve Flowbits — ☑ If checked, Snort will auto-enable rules required for checked flowbits. Default is Checked.
Snort will examine the enabled rules in your chosen rule categories for checked flowbits. Any rules that set these dependent flowbits will be automatically enabled and added to the list of files in the interface rules directory.

2

Auto-Flowbit Rules — View
Disabling auto-flowbit rules is strongly discouraged for security reasons. Auto-enabled flowbit rules that generate unwanted alerts should have their GID:SID added to the Suppression List for the interface instead of being disabled.

Snort Subscriber IPS Policy Selection

Use IPS Policy — ☑ If checked, Snort will use rules from one of three pre-defined IPS policies in the Snort Subscriber rules. Default is Not Checked.
Selecting this option disables manual selection of Snort Subscriber categories in the list below, although Emerging Threats categories may still be selected if enabled on the Global Settings tab. These will be added to the pre-defined Snort IPS policy rules from the Snort VRT.

IPS Policy Selection — Connectivity
Snort IPS policies are: Connectivity, Balanced, Security or Max-Detect.
Connectivity blocks most major threats with few or no false positives. Balanced is a good starter policy. It is speedy, has good base coverage level, and covers most threats of the day. It includes all rules in Connectivity. Security is a stringent policy. It contains everything in the first two plus policy-type rules such as a Flash object in an Excel file. Max-Detect is a policy created for testing network traffic through your device. This policy should be used with caution on production systems!

Select the rulesets (Categories) Snort will load at startup

- Category is auto-enabled by SID Mgmt conf files

covers most threats of the day. It includes all rules in Connectivity. Security is a stringent policy. It contains everything in the first two plus policy-type rules such as a Flash object in an Excel file. Max-Detect is a policy created for testing network traffic through your device. This policy should be used with caution on production systems!

Select the rulesets (Categories) Snort will load at startup

- Category is auto-enabled by SID Mgmt conf files
- Category is auto-disabled by SID Mgmt conf files

1 → Select All | Unselect All | Save

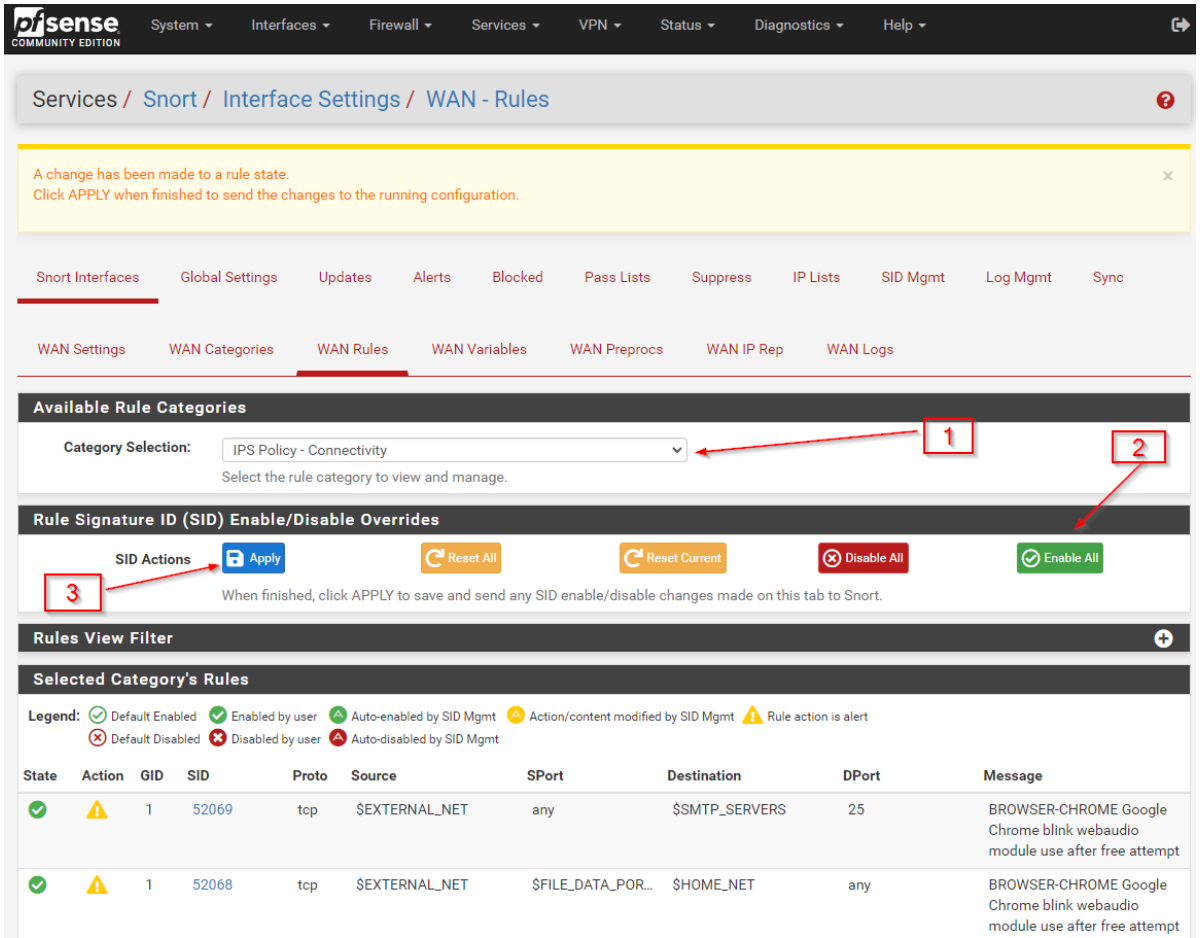
Enable	Ruleset: Snort GPLv2 Community Rules
☑	Snort GPLv2 Community Rules (Talos certified)

Enable	Ruleset: FEODO Tracker Botnet C2 IP Rules
☑	Feodo Tracker Botnet C2 IP Rules

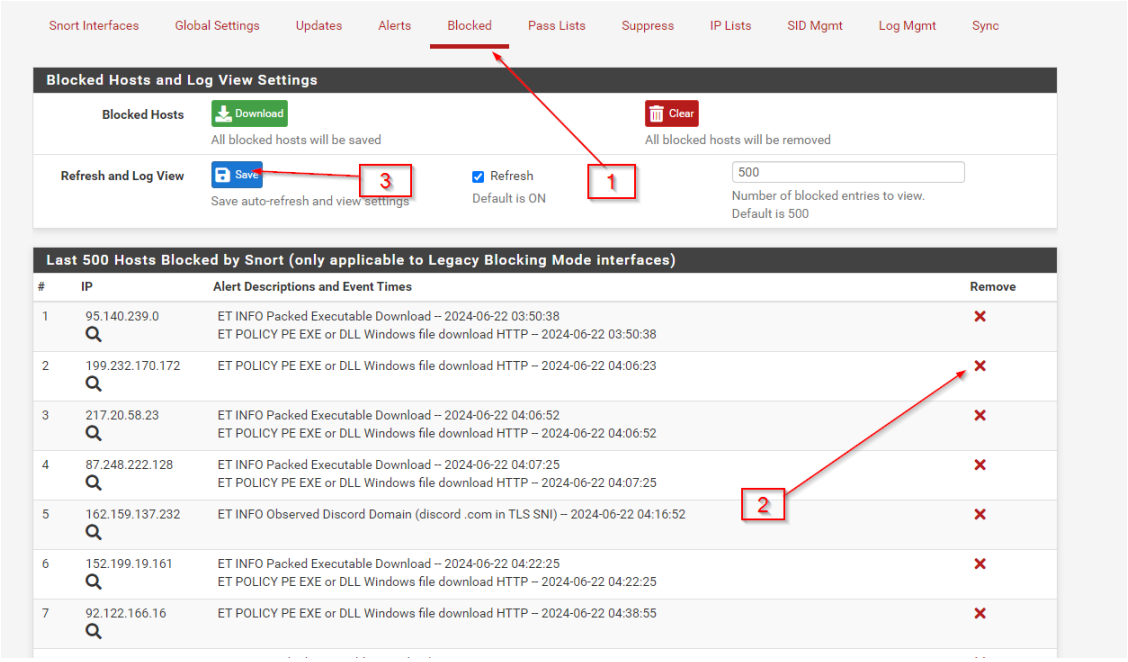
2

Enable	Ruleset: ET Open Rules	Enable	Ruleset: Snort Text Rules	Enable	Ruleset: Snort SO Rules	Enable	Ruleset: Snort OPENAPPID Rules
☑	emerging-activex.rules	☐	snort_app-detect.rules	☐	snort_browser-chrome.so.rules	☑	openappid-ads.rules
☑	emerging-attack_response.rules	☐	snort_attack-responses.rules	☐	snort_browser-ie.so.rules	☑	openappid-browser_plugin.rules
☑	emerging-botcc.portgrouped.rules	☐	snort_backdoor.rules	☐	snort_browser-other.so.rules	☑	openappid-bussiness_applications.rules
☑	emerging-botcc.rules	☐	snort_bad-traffic.rules	☐	snort_browser-webkit.so.rules	☑	openappid-collaboration.rules
☑	emerging-chat.rules	☐	snort_blacklist.rules	☐	snort_exploit-kit.so.rules	☑	openappid-database.rules
☑	emerging-ciarmy.rules	☐	snort_botnet-cnc.rules	☐	snort_file-executable.so.rules	☑	openappid-file_storage.rules
☑	emerging-compromised.rules	☐	snort_browser-chrome.rules	☐	snort_file-flash.so.rules	☑	openappid-file_transfer.rules
☑	emerging-current_events.rules	☐	snort_browser-firefox.rules	☐	snort_file-image.so.rules	☑	openappid-games.rules
☑	emerging-deleted.rules	☐	snort_browser-ie.rules	☐	snort_file-java.so.rules	☑	openappid-hacktools.rules
☑	emerging-dns.rules	☐	snort_browser-other.rules	☐	snort_file-multimedia.so.rules	☑	openappid-mail.rules
☑	emerging-dos.rules	☐	snort_browser-plugins.rules	☐	snort_file-office.so.rules	☑	openappid-messaging.rules
☑	emerging-drop.rules	☐	snort_browser-webkit.rules	☐	snort_file-other.so.rules	☑	openappid-mobile.rules
☑	emerging-dshield.rules	☐	snort_chat.rules	☐	snort_file-pdf.so.rules	☑	openappid-network_manager.rules
☑	emerging-exploit.rules	☐	snort_content-replace.rules	☐	snort_indicator-shellcode.so.rules	☑	openappid-network_monitor.rules

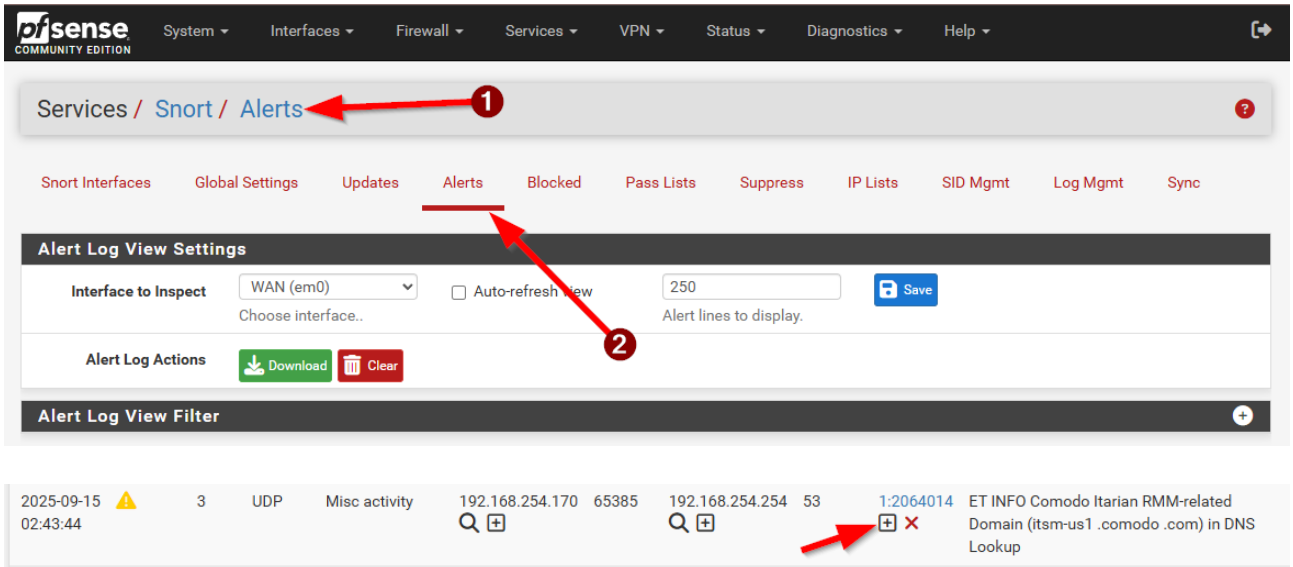
- Rendez-vous ensuite dans l'onglet « Wan Rules »



- Puis, rendez-vous dans l'onglet « Blocked »



Pour autoriser des codes IP :
- Allez dans "Alerts"
- Trouver le code IP que vous voulez autoriser, puis cliquez sur la croix à côté (autorisation temporelle).
- Pour autoriser des codes IP (définitivement) :
- Soit l'ajouter à la "Pass Lists" (demande un redémarrage de pfSense)
- Soit cliquer sur le petit plus, dans un carré, en dessous de "GID:SID" (plus rapide, demande qu'un redémarrage de l'interface WAN). (De loin la meilleure méthode pour moi, c'est celle que j'utilise tout le temps) :



- Redémarrez votre pfSense.

Test d'attaques

- Effectuez les tests suivants depuis un terminal dans la machine Kali Linux (qui doit être en accès par pont) :

nmap -sS <IPWAN_pfSense>

Quelles alertes sont générées ? Comment Snort détecte-t-il un scan ?

- Faites une sauvegarde de votre pfSense (instantanée) et modifiez vos paramètres pour protéger des attaques venant du LAN également.